

exosphere-audit

A supply-chain safety auditor for Claude Code skills & plugins

IDEA dossier · discovery → ideation · 2026-06-06

“the exosphere will not be televised” — but the skills you install should be audited before they run.

1 The opportunity

Agent skills are **executable markdown plus scripts that run with your shell’s authority**, and the bar to publish one is a `SKILL.md` and a week-old GitHub account — no review, no signing, no sandbox by default. The threat is not theoretical: a coordinated malware campaign (ClawHub) shipped 30+ malicious skills, and Snyk’s **ToxicSkills** study found prompt injection in more than a third of the skills it tested. Yet there is still no frictionless, trustworthy way to check that a skill is safe **before** you run it. `exosphere-audit` is that one-line check.



Share of tested skills carrying prompt injection — Snyk ToxicSkills

36%

2 Why now · why this · why you

- **Why now** — the supply-chain attack wave on agent skills is breaking this quarter, not next year.
- **Why this** — a FOSS, npx-frictionless, **explainable** auditor backed by a community-owned ruleset.
- **Why you** — native fit with the **idea-to-production** marketplace and the **SENTINEL** plugin; an existing, trusting audience; the objective is **reach and reputation**, not revenue.

3 The scorecard

Scored A–E under the **reach** objective: success is adoption, not a defended moat.

Axis	Mark	Note
A — Demand	PASS	Live, evidenced (ClawHub, Snyk ToxicSkills); pain on every install.
B — Market	PASS	Everyone installing third-party skills; reachable via ecosystem channels.
C — “Pay”	N/A	Reframed: success = adoption, not revenue. FOSS, \$0.
D — Moat	ACCEPTED	Incumbents exist; win on craft + distribution + native fit (Trivy-style).
E — Reach / Fit	PASS	npx zero-install; days-to-MVP; TS/Node → handler-js; strong builder edge.

4 The first slice — how the cautious installer moves through it

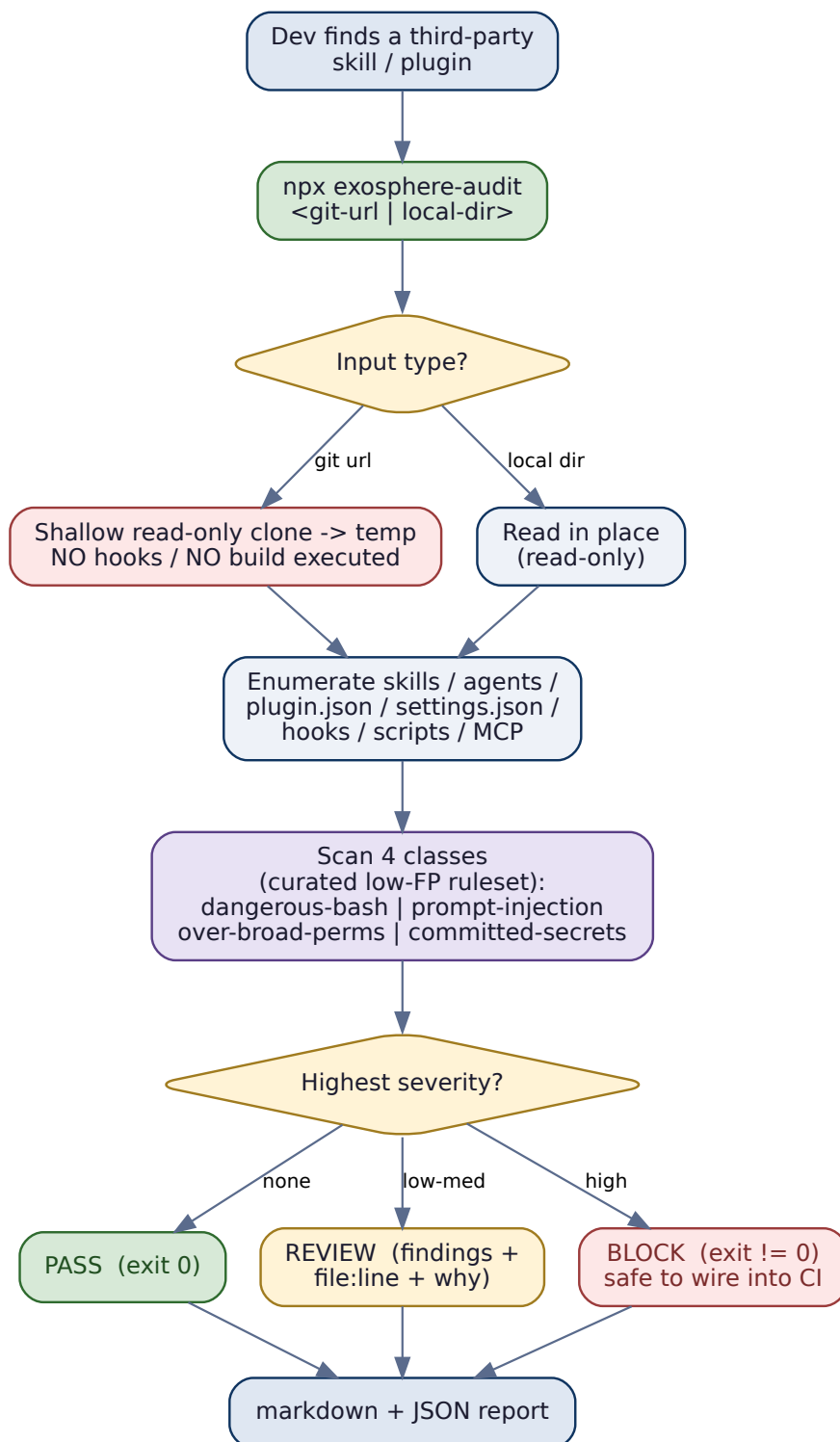


Figure 1: One command, a hostile-by-default read-only fetch, four detection classes, an explained verdict.

5 What it looks like

The terminal is the interface — a clear verdict, every finding tied to a `file:line` and a reason:

```

$ npx exosphere-audit github.com/acme/cool-skill
  fetched read-only (no hooks executed) · 14 files · 1 skill, 2 hooks

BLOCK (1 high, 2 medium)
high    dangerous-bash/exfil      hooks/post.sh:12    curl -s $URL | sh
        -> remote code piped to a shell; classic install-time RCE
medium  perms/over-broad          settings.json:4     "Bash(*)" allow-all
medium  prompt-injection/coerce   SKILL.md:31        "ignore previous safety
instructions"

verdict: BLOCK · report -> ./exosphere-audit.{md,json} · exit 3

```

6 The chosen-idea rationale

Three market-scan passes proved the developer / AI-agent-tooling niche is saturating — free OSS, funded security vendors, **and** Anthropic absorbing tool-gaps weekly. Rather than chase a moat that will not hold, the objective was reframed to **reach and reputation**: build the cleanest, most trustworthy, best-distributed FOSS auditor in the ecosystem, native to the marketplace — and let the **open ruleset** be the thing the community reaches for and contributes to. The first slice proves the whole thesis end-to-end in days.

Success metric (testable). On a labelled corpus of malicious + benign skills, v1 classifies $\geq 90\%$ correctly at $\leq 10\%$ false-positive, and every BLOCK cites file:line + the triggering rule. Detection **precision** is the product — a noisy security tool loses the trust that earns reach.